Handout S03: Hạ tầng CA Phân tầng, Quy chế CP/CPS & Cấp phát Tự động ACME

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Đơn vị: Khoa An toàn Thông tin — Phân hiệu Học viện Kỹ thuật Mật mã tại TP.HCM
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Kiến trúc Phân tầng CA Đa cấp (Multi-tier CA Hierarchy)

Mô hình phân tầng bảo đảm phân tách rủi ro giữa việc duy trì gốc tin cậy lâu dài và hoạt động cấp phát thường nhật:

```
graph TD
    Root["<b>Root CA (Gốc)</b><br/>Lưu trữ: Offline / Air-gapped (Két sắt, USB cách ly)<br/>Thời

    Int1["<b>Issuing CA 01 (Public Web TLS)</b><br/>Lưu trữ: Online HSM mạng<br/>Thời hạn: 3 - 5

    Int2["<b>Issuing CA 02 (Zero Trust mTLS)</b><br/>Lưu trữ: Online HSM nội bộ<br/>Thời hạn: 3 -

    Server1["Web Server (End-Entity)<br/>Thời hạn: 90 ngày"]
    Server2["Microservice API<br/>Thời hạn: 24 giờ"]

    Root -->|Ký ủy quyền| Int1
    Root -->|Ký ủy quyền| Int2
    Int1 -->|Cấp phát tự động| Server1
    Int2 -->|Cấp phát định kỳ| Server2
```

---

2. Quy chế CP/CPS theo Chuẩn IETF RFC 3647

Mọi hệ thống CA chuyên nghiệp bắt buộc phải vận hành dựa trên 2 bộ tài liệu pháp lý kỹ thuật: 1. **Certificate Policy (CP):** Bản tuyên ngôn quy định chứng chỉ được cấp cho ai, nhằm mục đích gì và mức độ tin cậy tương ứng. 2. **Certification Practice Statement (CPS):** Bản đặc tả chi tiết quy trình kỹ thuật vận hành để hiện thực hóa CP (cách sinh khóa, quy trình lưu trữ, nhân sự tham gia, biện pháp phục hồi thảm họa).

```
graph LR
    CP["<b>Certificate Policy (CP)</b><br/>Mục đích: Định nghĩa mức độ tin cậy<br/>Đối tượng: Khá
    CPS["<b>Certification Practice Statement (CPS)</b><br/>Mục đích: Hướng dẫn kỹ thuật vận hành<

    CP -->|Quy định 'Cái gì'| System["Hạ tầng Vận hành CA"]
    CPS -->|Quy định 'Làm như thế nào'| System
```

---

3. Giao thức Quản lý Chứng chỉ Tự động ACME (RFC 8555)

ACME (Automated Certificate Management Environment) giải quyết bài toán sai sót con người và chứng chỉ hết hạn bất ngờ:

```
sequenceDiagram
    autonumber
    actor Admin as Kỹ sư DevOps
    participant Client as ACME Client (Certbot / Step-CLI)
    participant Server as ACME Server (Step-CA / Boulder)
    participant DNS as DNS / Web Server

    Admin->>Client: Khởi tạo yêu cầu cấp phát chứng chỉ
    Client->>Server: Tạo tài khoản & Gửi yêu cầu (New Order)
    Server-->>Client: Trả về Thử thách Xác thực (HTTP-01 / DNS-01 Challenge)
    Client->>DNS: Cấu hình bản ghi TXT hoặc tệp HTTP Token
    Client->>Server: Thông báo đã sẵn sàng kiểm tra (Respond Challenge)
    Server->>DNS: Xác minh quyền sở hữu tên miền
    Server-->>Client: Xác minh thành công (Valid)
    Client->>Server: Gửi CSR ký số (Finalize Order)
    Server-->>Client: Cấp phát và trả về Chứng chỉ X.509
```

---

4. Tài liệu Tham khảo Chuẩn Quốc tế

1. **IETF RFC 3647:** *Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework*, RFC Editor, 2003. rfc-editor.org/rfc/rfc3647
2. **IETF RFC 8555:** *Automatic Certificate Management Environment (ACME)*, RFC Editor, 2019. rfc-editor.org/rfc/rfc8555
3. **Smallstep Labs:** *Production PKI Architecture and Practical Step-CA Deployments*, 2024. smallstep.com/docs